

# Manual 19 — FedRAMP / FISMA Controlled Implementation

Controlled English master — development

**\*\*Series order:\*\*** 19

**\*\*Boundary:\*\*** Implementation guidance only. Keep FISMA statute, OMB/CISA policy, NIST guidance, FedRAMP program requirements, agency-specific requirements, and organizational procedures distinct. Do not claim that FedRAMP certification alone establishes agency authorization or blanket FISMA compliance.

## 1. Federal governance, purpose, and applicability

Define system/service scope, federal customer relationships, responsible organizations, applicable statutes/policies, authorization path, and accountable executives. Evidence: applicability memo, governance charter, source register, authorization-path decision. Reassess after customer, service, impact, or policy changes.

## 2. FISMA statutory context

Maintain a legal/policy source map identifying which obligations arise from FISMA and which arise from implementing policy or guidance. Assign legal/policy interpretation ownership. Evidence: statutory applicability analysis and policy cross-reference. Do not paraphrase guidance as statutory text.

## 3. FedRAMP program and authorization context

Determine whether the service follows a current Rev. 5 path, a FedRAMP 20x certification class, an agency-led authorization process, or another officially supported route. Evidence: pathway decision, sponsor/customer record, marketplace status, transition plan. Reverify the pathway before major submission milestones.

## 4. NIST Risk Management Framework relationship

Use the RMF as a risk-management lifecycle model while preserving agency and FedRAMP-specific decision authority. Map Prepare, Categorize, Select, Implement, Assess, Authorize, and Monitor activities to owners and evidence. Test that lifecycle decisions are traceable and current.

## 5. SP 800-53 control-baseline relationship

Maintain the applicable control baseline and parameter sources without reproducing protected or obsolete program material. Record tailoring, inheritance, overlays, organization-defined parameters, and rationale. Evidence: control matrix and baseline provenance.

## 6. System categorization and impact analysis

Document information types, confidentiality/integrity/availability impact analysis, categorization basis, and approving authority. Evidence: categorization worksheet, data inventory, impact rationale. Reassess after material data or mission changes.

## **7. Authorization boundary and component inventory**

Define the authorization boundary, external services, interconnections, inherited services, environments, components, data flows, and excluded assets. Evidence: boundary diagram, inventory, interfaces, rationale. Test technical discovery against documentation.

## **8. Control selection and tailoring**

Select controls based on applicable path, impact level/class, agency requirements, risk, and current FedRAMP rules. Record additions, removals, tailoring, parameters, inheritance, and approvals. Evidence: tailored control set and decision log.

## **9. Overlays and agency-specific requirements**

Identify overlays and customer/agency-specific requirements separately from generally applicable program controls. Evidence: overlay register and contract/agency mapping. Prevent local requirements from being generalized across unrelated customers.

## **10. Control implementation statements**

Write implementation statements that identify responsible component, procedure, frequency/trigger, evidence, inheritance, and exceptions. Avoid aspirational language unsupported by operating evidence. Test sampled statements against actual configurations and procedures.

## **11. Roles, accountability, and segregation of duties**

Define CSP, agency, assessor, authorizing official, system owner, security, privacy, operations, engineering, and service-provider roles. Evidence: RACI, charters, delegations, conflict-of-interest controls. Preserve authorization and independent-assessment judgment boundaries.

## **12. Identity, access, and privileged administration**

Implement identity lifecycle, least privilege, MFA, privileged access management, service-account governance, periodic review, and emergency access. Evidence: access records, PAM logs, MFA coverage, review results. Test dormant, excessive, and unmanaged access.

## **13. Configuration and change management**

Maintain approved baselines, configuration standards, change approvals, emergency changes, drift detection, and rollback. Evidence: baselines, scans, change tickets, exceptions. Significant changes must trigger authorization-impact analysis.

## **14. Vulnerability and patch management**

Define scanning coverage, severity/risk prioritization, remediation timelines, exception handling, validation, and reporting. Evidence: scan outputs, tickets, risk decisions, retests. Track aging and recurring vulnerabilities.

## **15. Logging, monitoring, and detection**

Define required event sources, time synchronization, retention, protection, detection use cases, alert ownership, escalation, and evidence availability. Evidence: logging standard, SIEM coverage, alert/ticket samples. Test representative detections end-to-end.

## **16. Incident response and federal reporting interfaces**

Maintain incident identification, containment, recovery, evidence preservation, customer/agency escalation, and applicable federal reporting workflows. Evidence: IR plan, contact matrix, exercises, incident records. Reverify reporting requirements when policy changes.

## **17. Contingency planning and resilience**

Align business impact, backup, recovery, alternate processing, communications, and security during recovery. Evidence: contingency plan, test results, recovery metrics, backup validation. Ensure emergency recovery does not silently bypass required controls.

## **18. Cryptographic and key-management controls**

Define approved cryptographic use, key lifecycle, certificates, secrets, encryption in transit/at rest, and exception handling consistent with applicable federal requirements. Evidence: crypto inventory, key records, configuration samples, exception approvals.

## **19. Supply-chain and third-party risk**

Govern external services, software, components, subcontractors, inherited controls, provenance, incidents, and concentration risk. Evidence: supplier inventory, due diligence, contracts, SBOM/component records where applicable, monitoring results.

## **20. Cloud service and shared-responsibility boundaries**

Map provider, CSP, customer/agency, and external-service responsibilities for each relevant control. Evidence: responsibility matrix, inheritance statements, architecture evidence. Test for gaps created by assumed responsibility.

## **21. Secure development and system lifecycle**

Integrate security/privacy requirements into design, code, dependencies, build/release, secrets, testing, deployment, and decommissioning. Evidence: SDLC records, security tests, dependency evidence, release approvals. Significant releases require authorization-impact review.

## **22. Assessment planning and evidence collection**

Define assessment scope, procedures, sampling, evidence requests, repositories, chain-of-custody, and issue handling. Evidence must be current, reproducible, attributable, and mapped to implementation statements. Automation may support collection but does not replace assessor judgment.

## **23. Assessor independence and assessment boundaries**

Document applicable assessor qualification/independence requirements for the selected authorization or certification path. Keep readiness assistance separate from conclusions requiring independent assessment. Evidence: engagement scope, independence/competence record, assessment plan.

## **24. Findings, POA&M, and remediation governance**

Record findings, severity/risk, root cause, owner, milestones, compensating safeguards, due dates, evidence, validation, and closure authority. Evidence: POA&M/findings register and retest records. Prevent administrative closure without objective remediation evidence.

## **25. Authorization package architecture**

Maintain authoritative package components, ownership, versioning, consistency checks, and submission/review status. Separate evidence preparation from authorizing decisions. Evidence: package index, SSP/package components, assessment results, decision records as applicable to the path.

## **26. OSCAL and machine-readable package concepts**

Use OSCAL or other officially supported machine-readable structures where applicable to improve consistency and automation. Preserve human-readable source meaning, provenance, schema version, and validation. Automation must fail closed on invalid or incomplete transformations.

## **27. Continuous monitoring**

Define recurring control monitoring, vulnerability/configuration updates, evidence refresh, reporting, risk review, and customer/agency interfaces. Evidence: continuous-monitoring plan, recurring submissions, metrics, findings, change records.

## **28. Significant change and reassessment triggers**

Define triggers such as architecture, boundary, identity, crypto, data, hosting, major version, acquisition, incident, supplier, or authorization-path changes. Evidence: change-impact assessments and reauthorization/reassessment decisions.

## **29. FedRAMP 20x / Rev. 5 transition decision points**

Maintain a dated transition register. As of the controlled source verification, 20x Phase 3 is active; Class A opened August 3, 2026; Class B/Class C pipelines are scheduled for August 31, 2026; new Rev. 5 certifications are targeted to end June 11, 2027; and Consolidated Rules 2026 mandatory adoption is identified for January 1, 2027 subject to rule-specific applicability. Reverify every date before release and before using it operationally.

## **30. Certification and authorization maintenance**

Track continuing conditions, marketplace/program status where applicable, agency authorization conditions, recurring assessments, monitoring, remediation, and change notifications. Evidence: maintenance calendar, submissions, decisions, status records. Do not describe certification maintenance as replacing agency risk acceptance.

## **31. Source-watch, policy-change, and effective-date control**

Monitor official FedRAMP, NIST, OMB, CISA, statutory, and relevant agency sources. Record source URL, publication/effective date, applicability, impact, owner, and required manual/control changes. Material changes reopen affected review and release gates.

## **32. Localization, rendered QA, provenance, and release controls**

Freeze exact English source before es-419 and pt-BR localization. Preserve federal-program terminology and distinguish unofficial project localizations from authoritative source text. Before publication require structure/parity checks, documented genuine-human substantive reviews where explicitly required, rendered/page/accessibility inspection, reproducible six-binary DOCX/PDF generation, exact SHA-256 identities, durable staging, workflow-security and release-package QA, current source reversion, predecessor publication, and catalog/release-registry reconciliation.

### **Controlled release boundary**

This development master is not a FedRAMP certification, agency authorization, FISMA attestation, legal determination, or publication claim. Release remains fail-closed under the repository controls and sequential publication order.